

X-39MATRIX Bug Bounty Program

Sovereign Topos Protocol · Version 1.0 · Effective 2026-06-22

Program Summary

Program Type	Scope	Rewards	Response SLA
Public, Open HackenProof platform	11 ICP canisters mainnet + verify scripts + axioms	USD 100 - 50,000 Per severity matrix	First response < 24 h Triage < 72 h

X-39MATRIX is the first production-grade **quadruple post-quantum signed** sovereign protocol with threshold-ECDSA Bitcoin signing without human keys. The system is composed of **11 live ICP mainnet canisters** (9 layers x 5 functional blocks = 45 strata) anchored cross-substrate in Bitcoin mainnet (9 OTS anchors), Arbitrum One, and Solana mainnet.

This bounty program rewards security researchers who discover, responsibly disclose, and help remediate vulnerabilities in our production infrastructure. Findings that demonstrate concrete compromise of integrity, availability, or sovereignty primitives qualify for the highest tier.

1. In-Scope Assets

All 11 production canisters on ICP mainnet:

Layer	Canister Name	Canister ID	Lang	Module Hash (16)
HUB Omega	x39_bases (Sovereign Topos)	arn4r-lqaaa-aaaao-baxwq-cai	Rust	e4ba50b898a935c7
L1	Infrastructure	b4dy7-eyaaa-aaaao-baxra-cai	Motoko	a04f2a1305bd0998
L2	Identity (Merkle ZK-KYC)	b3c6l-jaaaa-aaaao-baxrq-cai	Motoko	a740ea69bece1810
L3	Execution (Ed25519)	akiau-riaaa-aaaao-baxua-cai	Motoko	ad721c0155e3a926
L4	Consensus (tECDSA)	anjga-4qaaa-aaaao-baxuq-cai	Motoko	d9dbfba7084d8aea
L5	Scalability (OmniChain)	s4zl3-eiaaaa-aaaao-bay3a-cai	Motoko	fd1ddbef113428b5
L6	Identity SSI / Bridge	adlli-haaaa-aaaao-baxvq-cai	Motoko	8b51571fbb909971
L7	AI Governance (PTU-47)	awm2f-giaaaa-aaaao-baxwa-cai	Rust	b65cc8b9ab5ae6f1
L8	Notarization (corebackend)	bsbvx-7iaaaa-aaaao-baxqa-cai	Motoko	4709f6a15a2262e7
FRONT	Web frontend (3 domains)	bvatd-sqaaa-aaaao-baxqq-cai	Assets	04e565b3425fe751
DASH	Public Dashboard (evidence)	nsy7t-jiaaaa-aaaau-agwra-cai	Assets	04e565b3425fe751

Additional in-scope assets:

- Verification script: https://x39matrix.org/PUBLIC_VERIFY_X39_FULL.sh
- Public web: <https://x39matrix.org>, <https://www.x39matrix.org>, <https://evidences.x39matrix.org>
- Lightning Address (LNURL proxy): grants@pay.x39matrix.org
- GitHub canonical repository: <https://github.com/x39matrix/x39matrix>
- Seven Sovereign Axioms A1-A7 sealed in Bitcoin block #948027
- Cross-substrate anchors: Arbitrum One contract + Solana mainnet program (TXIDs in /evidence)

2. Out of Scope

1. ICP boundary nodes infrastructure (managed by DFINITY) - report to DFINITY directly
2. Bitcoin mainnet protocol itself - report to Bitcoin Core security
3. Third-party libraries (rustcrypto, candid, etc.) - report upstream first, mirror to us
4. Social engineering of the Sovereign Operator or trustees
5. Physical attacks (lab access, side-channel via hardware)

6. DoS / DDoS without code-execution proof (rate-limiting is upstream responsibility)
7. Findings on backup repositories, archived branches, or x39matrix_backup_* directories
8. Self-XSS or attacks requiring victim to disable security warnings
9. Recent disclosure already public (check our /evidence directory before submitting)

3. Severity Matrix and Rewards

Rewards are based on impact severity and exploitability. The Sovereign Operator reserves final determination. We pay in **BTC** or **USD-stablecoin** via the Lightning Address bounty@pay.x39matrix.org or wire transfer (researcher choice).

Severity	CVSS	Description	Reward (USD)	Example
CRITICAL	9.0-10.0	Unauthorized BTC tECDSA signing, bypass of sovereignty, stable memory corruption, PGP key compromise	USD 25,000 - 50,000	Forged ML-DSA-87 signature, threshold takeover
HIGH	7.0-8.9	Inter-canister authentication bypass, OTS chain corruption, partial state rewrite	USD 15,000 - 25,000	Bypass partial state read of threshold majority
MEDIUM	4.0-6.9	Logical bugs in business flow without privilege escalation, PGP key compromise	USD 5,000 - 10,000	Stored with Sovereigns, board, frontend XS
LOW	0.1-3.9	Best-practice deviations, missing security headers, weak cryptography, information disclosure	USD 1,000 - 5,000	Disclose configuration metadata, version banners
INFO	0.0	Hardening suggestions without exploitable impact, documentation gaps	hallo! Pagers	Improve docs

4. Pre-Documented Collapse Attacks (Defense Baseline)

X-39MATRIX has been hardened against the following 10 attack categories. **Demonstrating that any of these collapses succeed against the live mainnet canisters automatically qualifies as CRITICAL.** The defensive layer "PTU-47" (Layer 7, AI Governance) monitors and resists them continuously.

ID	Attack Vector	Defense Mechanism
ATK-01	Quantum-cryptanalytic break of ECDSA/Ed25519	ML-DSA-87 + SLH-DSA dual cover
ATK-02	Threshold subnet collusion (more than 1/3 nodes)	ICP subnet randomness + cross-substrate anchor
ATK-03	Stable memory corruption via crafted upgrade	Schema versioning + invariant checks
ATK-04	OTS chain rollback (rewrite history)	Triple OTS attestation on Bitcoin mainnet (cost-prohibitive)
ATK-05	L4 consensus rule injection	Axiom A4 hard-coded + L9 categorical algebra check
ATK-06	Cross-substrate replay (BTC<->Arbitrum<->Solana)	Nonce isolation per substrate + epoch binding
ATK-07	PGP key compromise of Sovereign Operator	Bus-factor-zero design + threshold-ECDSA on subnet
ATK-08	Frontend supply chain attack (DASH or FRONT)	Module hash sealed in BTC + SRI on all assets
ATK-09	Adversarial AI gaming PTU-47 defense	Bounded epistemic budget + falsifiability gate
ATK-10	Time-warp on canister timestamps	Bitcoin block hash as external clock anchor

5. Responsible Disclosure Process

Step 1 - Discovery

Conduct testing exclusively against the in-scope assets. Do not access, modify, or destroy data belonging to other users. Avoid traffic spikes that would impact availability.

Step 2 - Documentation

Prepare a clear writeup including: (a) affected asset, (b) repro steps, (c) proof of impact, (d) suggested remediation. PoC code must be minimal and non-destructive.

Step 3 - Encrypted Submission

Submit via HackenProof platform OR email security@x39matrix.org encrypted with our PGP key (fingerprint C3E062EB 251A1185 1C0B4FFD 06870F06 55D5BBE8).

Step 4 - Acknowledgment

Initial response within 24 hours. Triage decision within 72 hours.

Step 5 - Coordination

We coordinate remediation timeline (typical: 7-30 days for Medium+, immediate for Critical). Researcher kept in loop. Embargo respected.

Step 6 - Remediation Verification

Researcher invited to confirm fix. Re-test on staging or mainnet (with permission).

Step 7 - Reward Payout

Payment via Bitcoin Lightning Network (bounty@pay.x39matrix.org), on-chain BTC, or USD-stablecoin wire. Tax form W-8BEN / W-9 if researcher is US person.

Step 8 - Public Disclosure

After fix is deployed and verified, coordinated public disclosure. Researcher named (or anonymized by request) in our Hall of Fame and Bitcoin-anchored advisory.

6. Rules of Engagement (Safe Harbor)

1. By participating, you agree to act in good faith and avoid privacy violations, data destruction, or service disruption.
2. We will not pursue civil or criminal action for research conducted in accordance with this policy, and we recognize the Open Bug Bounty principles + DOJ CFAA exemptions for security research.
3. Do not access any account or data that is not yours during testing. Use test accounts you created.
4. If sensitive data is accidentally accessed (PII, keys, etc.), stop, do not store, and report immediately.
5. Automated scanning is permitted at moderate rates (max 5 req/s per canister) to avoid impacting service.
6. Researchers from OFAC-sanctioned jurisdictions cannot receive monetary reward (legal constraint); Hall of Fame recognition still applies.
7. All submissions become subject to coordinated public disclosure after remediation. Findings cannot be sold, shared, or disclosed unilaterally before our coordination.

7. Payment Methods

Method	Asset	Address / Endpoint	Notes
Lightning Network	BTC	bounty@pay.x39matrix.org	Instant, low fee, recommended <\$5K
Bitcoin on-chain	BTC	bc1q... (provided post-confirmation)	For >\$5K, fee deducted
USD-Coin (USDC)	USDC	ERC20 / Arbitrum (provided)	For non-crypto researchers
Wire transfer	USD/EUR	SEPA or SWIFT	Requires KYC, slower (3-5 days)

8. Contact & Hall of Fame

Security Operator: Jose Luis Olivares Esteban (Sovereign Operator)

Encrypted Email: security@x39matrix.org (PGP fingerprint: C3E062EB 251A1185 1C0B4FFD 06870F06 55D5BBE8)

HackenProof: <https://hackenproof.com/programs/x39matrix>

GitHub Security: <https://github.com/x39matrix/x39matrix/security/policy>

Hall of Fame: <https://x39matrix.org/hall-of-fame> (Bitcoin-anchored)

Lightning Bounty: bounty@pay.x39matrix.org

9. Program Updates

This document is versioned and its SHA-256 hash will be sealed in Bitcoin mainnet via OpenTimestamps at every revision. The canonical version always lives at https://x39matrix.org/X39MATRIX_BOUNTY_PROGRAM_v1.0.pdf. For real-time changes, follow @X39MATRIX on X (Twitter).

Document SHA-256: [to be sealed in BTC upon publication]

Effective Date: 2026-06-22 00:00 UTC

Next Review: 2026-09-22 (quarterly)

License: CC-BY-SA 4.0 (program text) · Code findings under coordinated disclosure